Πολιτική Χρήσης Φορητών Συσκευών Πληροφορικής

CULTURE FOR CHANGE

ΕΙΣΑΓΩΓΗ

Η Πολιτική αφορά το Σωματείο με την επωνυμία «Culture for Change» και με τον διακριτικό τίτλο «CforC», το οποίο εδρεύει στην Αθήνα επί της οδού Λ. Αλεξάνδρας 48, ΤΚ 11473, ΑΦΜ 996788256, ΔΟΥ Δ' Αθηνών. (επικοινωνία: hello@cultureforchange.net)και εκπροσωπείται νομίμως.

Η χρήση φορητών συσκευών πληροφορικής αυξάνεται όλο ένα και περισσότερο στην καθημερινή ζωή, καθώς οι συσκευές γίνονται μικρότερες και ισχυρότερες και ο αριθμός των εργασιών που μπορούν να επιτευχθούν μακριά από το γραφείο μεγαλώνει. Ωστόσο, καθώς αυξάνονται οι δυνατότητες, το ίδιο συμβαίνει και με τους κινδύνους. Οι έλεγχοι ασφαλείας που έχουν σχεδιαστεί για την προστασία ενός σταθερού σταθμού εργασίας παρακάμπτονται εύκολα όταν χρησιμοποιείται μια κινητή συσκευή εκτός των ορίων ενός οργανισμού.

Στις φορητές συσκευές πληροφορικής περιλαμβάνονται:

Laptops, Notebooks, Tablets, Smartphones, Smart watches, PDAs, Φωτογραφικές μηχανές, κάμερες.

Σκοπός αυτής της πολιτικής είναι να καθοριστούν οι έλεγχοι που πρέπει να εφαρμόζονται όταν γίνεται χρήση των φορητών συσκευών. Προορίζεται στο να μετριαστούν κίνδυνοι όπως:

- Απώλεια ή κλοπή κινητών συσκευών, συμπεριλαμβανομένων των δεδομένων αυτών
- Διαρροή πληροφοριών από οπτική παρακολούθηση οθονών
- Εισαγωγή ιών και κακόβουλου λογισμικού στο δίκτυο της επιχείρησης

Είναι σημαντικό οι έλεγχοι που καθορίζονται στην παρούσα πολιτική να τηρούνται πάντοτε κατά τη χρήση και τη μεταφορά κινητών συσκευών.

ΠΟΛΙΤΙΚΗ ΓΙΑ ΤΙΣ ΦΟΡΗΤΕΣ ΣΥΣΚΕΥΕΣ ΠΛΗΡΟΦΟΡΙΚΗΣ ΣΥΣΚΕΥΕΣ ΠΟΥ ΠΑΡΕΧΟΝΤΑΙ ΑΠΟ ΤΟΝ ΟΡΓΑΝΙΣΜΟ.

Εκτός από την περίπτωση που υπάρχει ειδική εξουσιοδότηση, πρέπει να χρησιμοποιούνται **μόνο** φορητές συσκευές που παρέχονται από τον Οργανισμό για την αποθήκευση ή την επεξεργασία διαβαθμισμένων.

Εάν απαιτείται να χρησιμοποιήσετε φορητές συσκευές πληροφορικής, θα σας δοθούν κατάλληλες συσκευές οι οποίες θα ρυθμιστούν ώστε να συμμορφώνονται με τις πολιτικές του οργανισμού. Υποστήριξη για αυτές θα παρέχεται από τον συνεργάτη υπεύθυνο πληροφορικής, ο οποίος ενδέχεται να χρειάζεται κάποιες φορές πρόσβαση στη συσκευή σας για σκοπούς επίλυσης προβλημάτων και συντήρησης.

Πρέπει να βεβαιωθείτε ότι η συσκευή μεταφέρεται σε **προστατευτική θήκη**, όταν αυτό είναι εφικτό, και ότι δεν εκτίθεται σε καταστάσεις στις οποίες ενδέχεται να καταστραφεί. Μην αφήνετε τη συσκευή αφύλακτη σε δημόσια προβολή, πχ στο αυτοκίνητο ή σε αίθουσα συσκέψεων κ.α.

Μην αφαιρέσετε τυχόν αναγνωριστικά της συσκευής, όπως π.χ. service tag, αριθμό παγίου ή σειριακό αριθμό. Βεβαιωθείτε ότι η συσκευή είναι **κλειδωμένη** όταν αποθηκεύεται και ότι το κλειδί δεν είναι εύκολα προσβάσιμο.

Μη συνδέετε περιφερειακές συσκευές στη φορητή συσκευή χωρίς την έγκριση του υπεύθυνου πληροφορικής. Πριν από την έξοδο της συσκευής από τη χώρα, πρέπει να συμβουλευτείτε τον υπεύθυνο πληροφορικής. Αυτό θα διασφαλίσει ότι η συσκευή θα λειτουργήσει και θα εξεταστούν τυχόν ασφαλιστικές συνέπειες.

Μην αποθηκεύσετε διαβαθμισμένες πληροφορίες στη συσκευή εκτός εάν αυτό έχει εγκριθεί και έχουν εγκατασταθεί τα κατάλληλα στοιχεία ελέγχου (π.χ. κρυπτογράφηση). Μην κρατάτε προσωπικά στοιχεία αναγνώρισης (π.χ. ταυτότητα), tokens πρόσβασης ή άλλα στοιχεία ασφάλειας μαζί / πάνω στην συσκευή.

Βεβαιωθείτε ότι **η οθόνη της συσκευής κλειδώνει** μετά από μια σύντομη περίοδο που δεν χρησιμοποιείται και απαιτεί κωδικό πρόσβασης ή κωδικό ασφαλείας για να την ξεκλειδώσετε. Οι χρησιμοποιούμενοι κωδικοί ασφαλείας πρέπει να είναι ισχυροί και δύσκολοι. Απαγορεύεται η δημιουργία μη διασφαλισμένων συνδέσεων (π.χ. δημιουργία χρήστη χωρίς την απαίτησή ύπαρξης κωδικού ασφαλείας) στη φορητή συσκευή.

Η συσκευή που παρέχεται προορίζεται για συγκεκριμένη χρήση μόνο. Δεν πρέπει να μοιράζεται με την οικογένεια ή τους φίλους ή να χρησιμοποιείται για προσωπικές δραστηριότητες. Ενδέχεται να σας ζητηθεί να επιστρέψετε τη συσκευή στον υπεύθυνο πληροφορικής ανά πάσα στιγμή για επιθεώρηση και έλεγχο. Δεν πρέπει να εγκαταστήσετε κανένα μη εξουσιοδοτημένο λογισμικό ή να αλλάξετε τη διαμόρφωση ή τη ρύθμιση της συσκευής χωρίς να συμβουλευτείτε πρώτα τον υπεύθυνο πληροφορικής. Δεν θα πρέπει να αποθηκεύετε αρχεία οποιασδήποτε μορφής (κειμένου, ήχου, εικόνας κλπ) που δεν σχετίζονται με την δραστηριότητα του project, ή αποτελούν προσωπικά δεδομένα δικά σας ή τρίτων. Σε κάθε περίπτωση, θα πρέπει να γνωρίζετε ότι ο οργανισμός θα έχει δυνατότητα ελέγχου της συσκευής :

- για συντήρηση της,
- για τροποποίηση των ρυθμίσεων της,
- για εγκατάσταση νέων λογισμικών ή ενημερώσεων υπαρχόντων λογισμικών,
- για τη διαπίστωση παραβάσεων των εταιρικών πολιτικών, ή διατάξεων νόμων σε βάρος του οργανισμού

κατόπιν ενημέρωσης σας.

Σε περίπτωση που παραστεί ανάγκη ελέγχου της συσκευής για τη διαπίστωση σοβαρών παραβάσεων (πχ ποινικών), αυτός θα επιτρέπεται εφόσον συντρέχουν σοβαρές ενδείξεις τους. Στην περίπτωση αυτή δεν θα υπάρξει προηγούμενη νεότερη ενημέρωση σας, για τη διασφάλιση του σκοπού του ελέγχου.
Οι «ελεγχόμενοι συνεργάτες» έχουν δικαίωμα να πληροφορούνται το αποτέλεσμα των ανωτέρω ελέγχων.
Όπου είναι δυνατόν, η συσκευή θα είναι ασφαλισμένη έτσι ώστε όλα τα δεδομένα σε αυτήν να είναι κρυπτογραφημένα και έτσι είναι διαθέσιμα μόνο εάν είναι γνωστός ο κωδικός πρόσβασης. Εάν η συσκευή είναι εφοδιασμένη με σύστημα κρυπτογράφησης, μην το απενεργοποιήσετε.
Οι αλλαγές στα αρχεία που διατηρούνται στη συσκευή ενδέχεται να μην λαμβάνονται σε αντίγραφα ασφαλείας σε τακτική βάση, εάν δεν έχει συνδεθεί η φορητή συσκευή στο εταιρικό δίκτυο για μια χρονική περίοδο. Μην λαμβάνετε τα δικά σας μη κρυπτογραφημένα αντίγραφα διαβαθμισμένων πληροφοριών.
Όπου είναι απαραίτητο, θα εγκατασταθεί από τον οργανισμό στη συσκευή, λογισμικό προστασίας από ιούς. Μην απενεργοποιείτε το λογισμικό προστασίας από ιούς στη συσκευή.
Όταν βρίσκεστε σε δημόσιους χώρους, βεβαιωθείτε ότι τοποθετήσατε τη συσκευή έτσι ώστε να μην είναι ορατή η οθόνη της σε μη εξουσιοδοτημένους χρήστες.

Σε περίπτωση διακοπής της συνεργασίας ή αποχώρησης από τον Οργανισμό, ο χρήστης της συσκευής θα πάψει να έχει δυνατότητα πρόσβασης και τροποποιήσεων στη συσκευή. Σε περίπτωση που κατά παράβαση της παρούσας πολιτικής, έχει αποθηκεύσει προσωπικές του πληροφορίες, θα πρέπει να υποδείξει στους αρμόδιους τα συγκεκριμένα αρχεία, τα οποία θα πρέπει να είναι προηγουμένως επισημασμένα ως προσωπικά (πχ σε ιδιαίτερο φάκελο αρχείων με τίτλο «προσωπικά») , ώστε να είναι δυνατόν να αιτηθεί και να λάβει αντίγραφο τους, αλλά και να διαγραφούν Ο οργανισμός αποποιείται οποιασδήποτε ευθύνης για τυχόν προσωπικές πληροφορίες που δεν έχουν επισημανθεί από το χρήστη ως τέτοιες. Σε κάθε περίπτωση, εάν διαπιστωθεί η ύπαρξη τέτοιων αρχείων, ο οργανισμός θα δικαιούται να τα διαγράψει, άνευ νεότερης ενημέρωσης του χρήστη.

ΧΡΗΣΗ ΠΡΟΣΩΠΙΚΩΝ ΦΟΡΗΤΩΝ ΣΥΣΚΕΥΩΝ (BYOD)

Το χαμηλό κόστος και η γενική διαθεσιμότητα τέτοιων συσκευών πυροδότησε την επιθυμία των ανθρώπων που ασχολούνται με την τεχνολογία, να χρησιμοποιήσουν τις δικές τους συσκευές για επαγγελματική χρήση. Αυτό συνήθως αναφέρεται ως "Φέρτε τη δική σας συσκευή" (Bring Your Own Device, BYOD). Σε ορισμένες περιπτώσεις, αυτό μπορεί να προσφέρει μεγάλη ευελιξία και να καταργήσει την ανάγκη για τον συνεργάτη να μεταφέρει περισσότερες από μία συσκευές σε τακτική βάση.

Ωστόσο, το γεγονός του να επιτρέπεται σε έναν συνεργάτη να χρησιμοποιεί τη δική του συσκευή (συσκευές) για τους σκοπούς του οργανισμού μπορεί να οδηγήσει στην

ανάγκη οι συσκευές αυτές να υπόκεινται σε πρόσθετους ελέγχους πέρα από εκείνους που συνήθως ισχύουν για μια συσκευή ιδιώτη.

Συχνά προβλήματα που αντιμετωπίζονται με τη χρήση των συσκευών BYOD είναι:

- Χρήση της συσκευής από άλλα μέλη της οικογένειας
- Προεπιλεγμένη αποθήκευση δεδομένων σε εγκαταστάσεις cloud
- Αυξημένη πιθανότητα απώλειας της συσκευής σε κοινωνικές καταστάσεις, π.χ. στην παραλία ή σε μια καφετέρια κ.α.
- Πιθανότητα πρόσβασης σε ιστότοπους που δεν πληρούν τις αποδεκτές πολιτικές χρήσης του οργανισμού.
- Σύνδεση σε μη ασφαλή δίκτυα, π.χ. μη ασφαλή ασύρματα δίκτυα (hotspots)
- Προστασία από ιούς και πόσο συχνά η συσκευή έχει αναβαθμιστεί
- Εγκατάσταση δυνητικά κακόβουλων εφαρμογών στη συσκευή (συχνά χωρίς να γνωρίζει ο χρήστης ότι είναι κακόβουλοι)

Τα παραπάνω ζητήματα πρέπει να λαμβάνονται σοβαρά υπόψη κατά την αξιολόγηση της καταλληλότητας οποιασδήποτε προσωπικής συσκευής για την επεξεργασία συγκεκριμένων δεδομένων.
Είναι σημαντικό οι έλεγχοι που καθορίζονται στην παρούσα πολιτική να τηρούνται πάντοτε κατά τη χρήση φορητών συσκευών BYOD. Οι συνεργάτες δεν πρέπει να χρησιμοποιούν τις δικές τους συσκευές για να κρατούν και να επεξεργάζονται τις πληροφορίες του Οργανισμού εκτός εάν έχουν υποβάλει σχετικό αίτημα πριν και το αίτημα έχει εγκριθεί επισήμως. Αποτελεί πολιτική του Οργανισμού να αξιολογεί κάθε αίτημα BYOD σε ατομική βάση για να καθορίσει:

- Την ταυτότητα του αιτούντος
- Τον λόγο της αίτησης
- Τα δεδομένα που θα αποθηκευτούν ή θα υποβληθούν σε επεξεργασία στη συσκευή
- Τη συγκεκριμένη συσκευή που θα χρησιμοποιηθεί

Τα αιτήματα πρέπει να υποβληθούν στον συνεργάτη πληροφορικής.

Η γενική αρχή αυτής της πολιτικής είναι ότι ο βαθμός ελέγχου που ασκείται από τον οργανισμό πάνω στην BYOD συσκευή θα είναι κατάλληλος και ανάλογος με τη φύση και την ευαισθησία των δεδομένων που τηρούνται σε αυτόν.

Οδηγίες που πρέπει να χρησιμοποιούνται στην απόφαση σχετικά με το ποιος θα πρέπει να έχει πρόσβαση σε ποιες πληροφορίες σχετικά με το ποια συσκευή συνοψίζεται στον Πίνακα 1 παρακάτω.

Προκειμένου να διασφαλιστεί ότι τα δεδομένα της προστατεύονται επαρκώς, είναι σημαντικό ο Οργανισμός να είναι σε θέση να παρακολουθεί και να ελέγχει το επίπεδο συμμόρφωσης με αυτήν την πολιτική. Το επίπεδο παρακολούθησης και ελέγχου θα είναι ανάλογο της διαβάθμισης των πληροφοριών που τηρούνται στη συσκευή.

Οι μέθοδοι και ο χρόνος παρακολούθησης και ελέγχου θα είναι τέτοιοι ώστε να μην προσβάλλεται η ιδιωτικότητας του ιδιοκτήτη της συσκευής και θα είναι σύμφωνοι με την ισχύουσα νομοθεσία περί προστασίας της ιδιωτικότητας.

Σε περίπτωση απώλειας ή κλοπής της συσκευής, ο ιδιοκτήτης πρέπει να ενημερώσει τον υπεύθυνο πληροφορικής το συντομότερο δυνατό, παρέχοντας λεπτομέρειες σχετικά με τις συνθήκες της απώλειας και την ευαισθησία των επιχειρηματικών πληροφοριών που είναι αποθηκευμένες σε αυτήν. Ο Οργανισμός διατηρεί το δικαίωμα να διαγράψει ολικά τη συσκευή, όπου αυτό είναι δυνατό, ως προφύλαξη ασφαλείας.

Σε περίπτωση διακοπής της σχέσης με τον οργανισμό, ο κάτοχος της συσκευής πρέπει να επιτρέψει τη διενέργεια ελέγχου και τη διαγραφή όλων των δεδομένων και εφαρμογών που σχετίζονται.

[ο παρακάτω πίνακας αποτελεί παράδειγμα της διαβάθμισης της πληροφορίας σε σχέση με τη χρήση συσκευών BYOD].

Διαβάθμιση πληροφορίας	**Παράδειγμα**	**Ποιος μπορεί να έχει πρόσβαση με BYOD**	**Τύποι συσκευών BYOD**	**Απαιτούμενοι έλεγχοι**	**Σχόλια**
Επίπεδο 0 – Δημόσιες (public)	δημόσια στοιχεία οργανισμού	Οποιοσδήποτε	Οποιαδήποτε	Κανένας	Αυτές οι πληροφορίες είναι δημόσιες και συνήθως υπάρχουν αναρτημένες στην ιστοσελίδα.
Επίπεδο 1 – Προστατευμένες (secured)	Εσωτερικές διαδικασίες, επικοινωνίες email.	Μέλη και συνεργάτες	Laptops Tablets Smartphones	Προστασία με κωδικό πρόσβασης, απομακρυσμένη διαγραφή, Anti-virus Περιοδικοί έλεγχοι	Αυτή η κατηγορία περιλαμβάνει το μεγαλύτερο ποσοστό χρήσης BYOD
Επίπεδο 2 – Περιορισμένες (restricted)	Πληροφορίες τραπεζικές **προσωπικά δεδομένα.**	Περιορισμένη ομάδα μελών ΔΣ συνεργατών	Μόνο Laptops	Πλήρης κρυπτογράφηση, VPN, Αυτόματες ενημερώσεις, Anti-virus Firewall Περιοδικοί έλεγχοι	Μόνο συσκευές με αυστηρούς ελέγχους μπορούν να έχουν αυτές τις πληροφορίες. Ουσιαστικά, δε πρέπει αυτές οι πληροφορίες να βρίσκονται σε συσκευές BYOD.
Επίπεδο 3 – Εμπιστευτικές (confidential)	Μελλοντικά σχέδια, συμφωνίες, που ακόμη είναι σε επεξεργασία	Κανένας	Καμία		Μόνο συσκευές που ανήκουν στον οργανισμό μπορούν να έχουν αυτές τις πληροφορίες.